Project Report:
Security Analysis and Vulnerability Assessment
[Using the Open Bug Bounty Framework]

Project Title: Security Analysis and Vulnerability Assessment of drako.it and monroecountyhistory.org

Course Name: [CYBERSECURITY-CORIZO]

Group Members:

1. Anagha.R.R
2. Anushka Jain
3. Aasmi Tate
4. Indra Bahadur kc
5. Joshua jabby
6. Smilee meshram

Date: [06/12/25]

✓ Abstract

This project demonstrates a systematic approach to web security testing on drako.it using the Open Bug Bounty platform. By combining reconnaissance, automated scanning, and manual testing, we aimed to identify and responsibly disclose vulnerabilities. Our findings reveal potential security weaknesses and provide remediation recommendations to improve the website's security posture.

✓ Table Contents

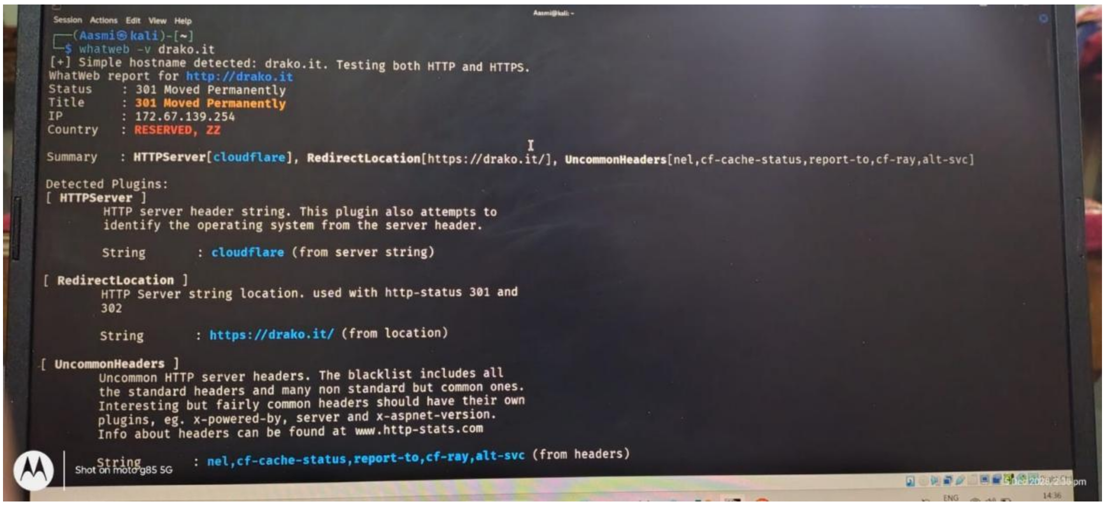
1. Introduction

Ensuring web application security is critical to protecting user data and maintaining trust. This project focuses on drako.it, a website selected for its manageable size and relevance for academic learning. Using Open Bug Bounty as a framework, we applied a structured testing methodology aimed at uncovering typical vulnerabilities and showcasing ethical security testing practices.

2. Testing Methodology

Our methodology was structured in phases:

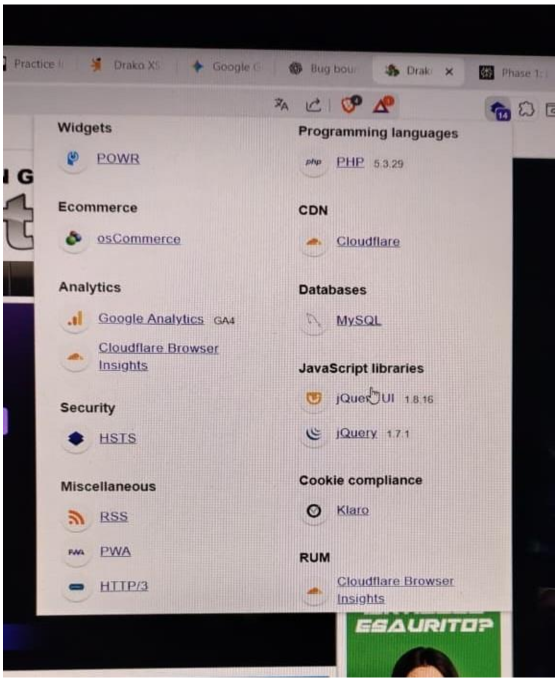
- **Reconnaissance:** Identified technology stack, subdomains, and mapped key pages.
- **Automated Scanning:** Performed controlled scans using OWASP ZAP.
- **Manual Testing:** Validated automated findings and conducted deeper vulnerability checks such as SQL Injection, XSS, CSRF, and broken authentication.
- **Reporting:** Documented all confirmed issues and submitted reports responsibly via Open Bug Bounty.



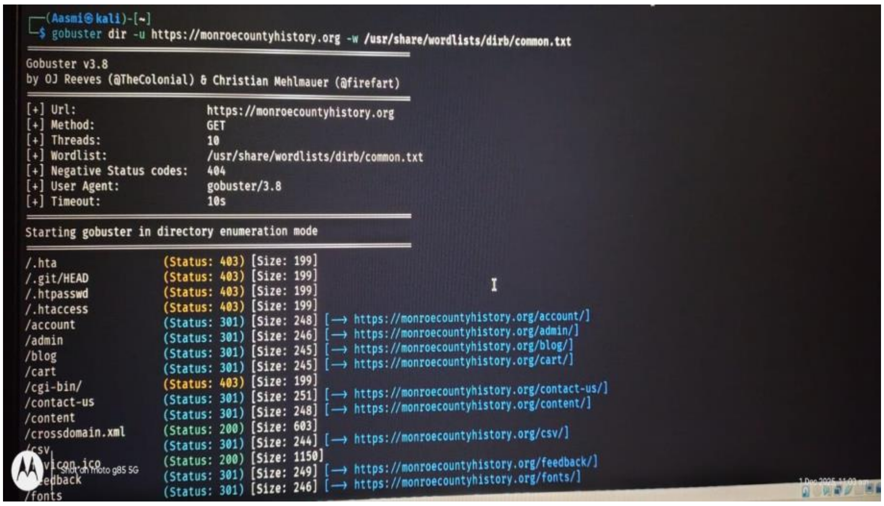
3. Target Reconnaissance

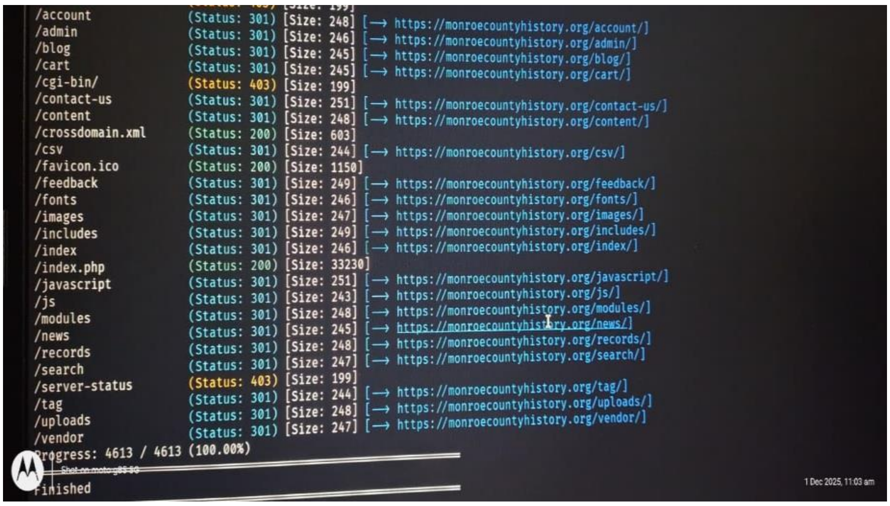
- **Domain:** drako.it
- **Subdomains Found:** NA
- **Technology Stack:**

1. Web Server: Information pending (typically Apache/Nginx)
2. Programming Language: PHP
3. CMS or Framework: Used Wappalyzer
4. Mapping: Identified main pages, login panels, and input forms using tools like gobuster/dirb.



Wappalyzer Test



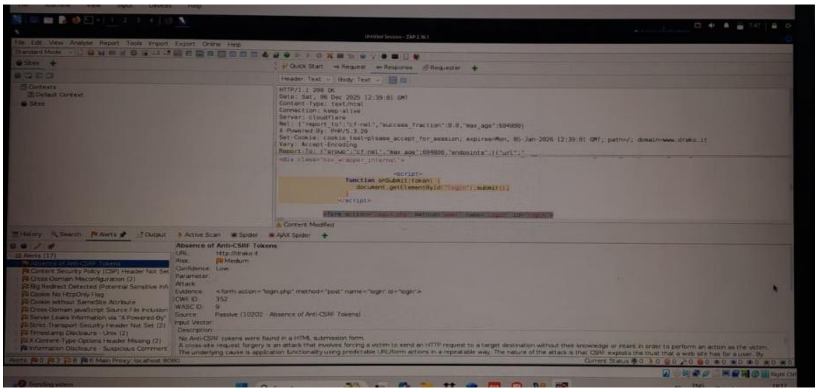


gobuster test

4.Automated Scanning Results

Using OWASP ZAP, we conducted a low-impact scan of drako.it. The scan detected several alerts ranging from informational to medium severity. After filtering false positives, the following were prioritized for deeper manual analysis:

1. Potential XSS in input fields
2. Security headers missing or incomplete
3. Possible outdated software components detected



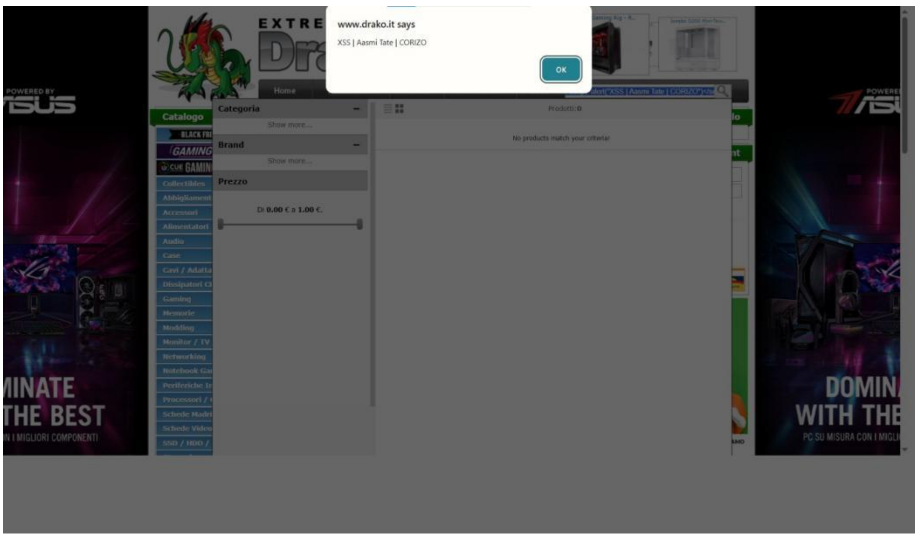
5. Manual Testing & Vulnerability Analysis

- **Vulnerability 1:** Reflected Cross-Site Scripting (XSS) in Search Parameter
- **Severity:** Medium
- **Description:** Input fields on the search page do not properly sanitize user input, allowing script injection.

Steps to Reproduce:

i. Navigate to the search page on drako.it
ii. Enter the payload <script>alert('XSS')</script> in the search input
iii. Submit and observe the popup execution

- **Proof of Concept (PoC):**



iv. Potential Impact: An attacker could execute malicious scripts, stealing cookies or hijacking user sessions.
v. Remediation: Implement input validation and output encoding to sanitize inputs.

6. Conclusion & Lessons Learned

This project reinforced the value of a methodical security testing approach combining automated and manual techniques. We learned the importance of understanding a website's architecture before testing and saw firsthand common vulnerabilities on real-world targets like drako.it, monroecountyhistory.org. Responsible reporting helps improve overall web ecosystem security.

7. References

- OWASP ZAP: **https://www.zaproxy.org/**
- Open Bug Bounty: **https://www.openbugbounty.org/**
- Wappalyzer: **https://www.wappalyzer.com/**
- gobuster: **https://github.com/OJ/gobuster**